

HiveForce Labs

THREAT ADVISORY



ATTACK REPORT

Malicious Ruby Gems Fuel GemStuffer Data Theft Campaign

Date of Publication

May 14, 2026

Admiralty Code

A1

TA Number

TA2026130

Summary

First Seen: May 2026

Targeted Region: United Kingdom

Targeted Platforms: RubyGems Package Registry, Ruby Runtime Environments, CI/CD Pipelines

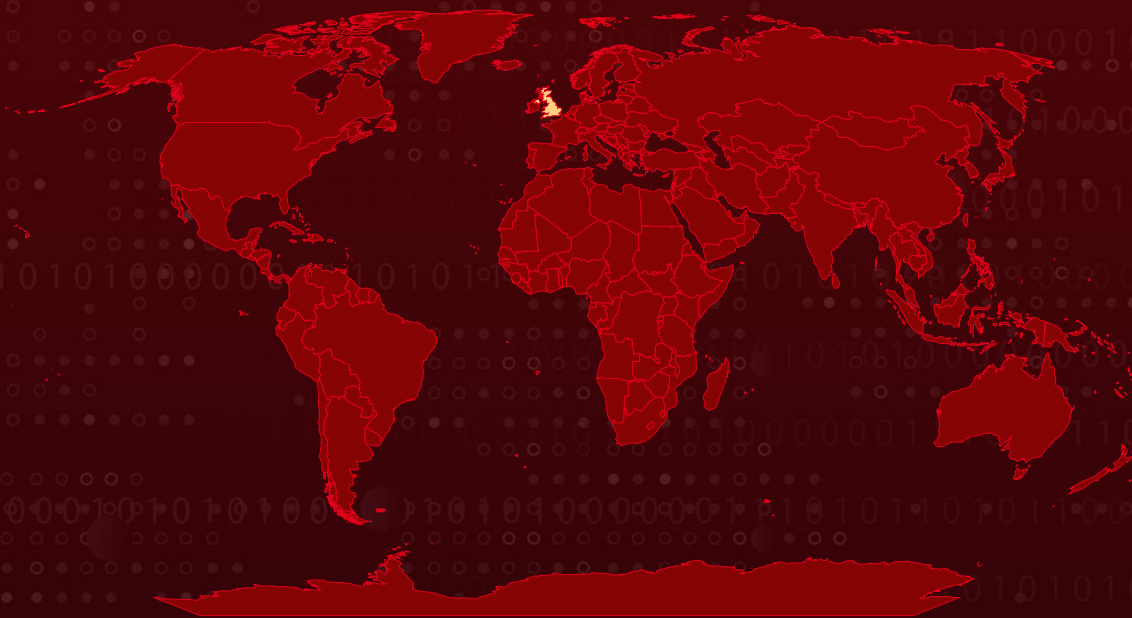
Targeted Products: ModernGov (UK Local Government Democratic Services Portal Software)

Targeted Industry: Government

Campaign: GemStuffer

Attack: The GemStuffer campaign is abusing the Ruby software ecosystem to quietly steal and exfiltrate sensitive government-related data through seemingly legitimate RubyGems packages. By slipping malicious Ruby scripts into compromised CI/CD pipelines, Bundler configurations, and gem installation hooks, the attackers scrape meeting calendars, agenda records, PDFs, and contact information from UK local government portals before packaging the stolen data into fake .gem archives. The operation stands out for its stealth and technical sophistication, using temporary staging directories, hardcoded RubyGems API keys, and legitimate gem publishing workflows to disguise exfiltration traffic as normal developer activity, making detection significantly more difficult.

🔪 Attack Regions



Powered by Bing

© Australian Bureau of Statistics, GeoNames, Microsoft, Navinfo, Open Places, OpenStreetMap, Overture Maps Fundation, TomTom, Zenrin

Targeted

Non-Targeted



THREAT ADVISORY • ATTACK REPORT (Red)

2

Hive Pro

Attack Details

#1

A supply chain campaign dubbed “GemStuffer” is abusing the Ruby ecosystem to quietly scrape sensitive government data and smuggle it out through seemingly legitimate RubyGems packages. The operation relies on malicious Ruby scripts disguised under filenames such as `payload.rb`, `exploit.rb`, `extconf.rb`, `yard_plugin.rb`, and `fetcher.rb`, which are introduced into target environments through compromised Bundler configurations, poisoned CI/CD pipelines, tampered gem post-install hooks, or malicious developer dotfile repositories. Once executed, the implant immediately gathers execution context, including timestamps, working directories, script paths, and command-line arguments, embedding this metadata alongside the stolen content to give operators detailed insight into the infected environment.

#2

At the center of the campaign is a targeted web-scraping operation focused on UK local government democratic services portals. Using Ruby’s built-in `Net::HTTP` library, the malware connects to hardcoded ModernGov-powered council sites, including Lambeth, Wandsworth, and Southwark portals, harvesting meeting calendars and committee agenda pages from `mgCalendarMonthView.aspx` endpoints. The script then parses the returned HTML to identify links tied to agenda listings and committee records before issuing additional requests to collect full meeting details, officer contact information, RSS feed data, and linked PDF documents. To blend into normal traffic, the implant spoofs a minimal “Mozilla/5.0” User-Agent string while deliberately suppressing SSL certificate verification errors during outbound requests.

#3

After gathering the data, the malware packages the stolen content into a fully functional `.gem` archive created inside temporary directories under `/tmp`. The scraped information is embedded into files such as `lib/result.txt` or `README`, alongside intentionally minimal `gemspec` metadata using placeholder author names and generic summaries to avoid drawing attention. The use of `File.binwrite` instead of the more common `File.write` allows the malware to safely handle raw non-UTF-8 HTTP response data, reflecting a high level of familiarity with Ruby internals. Some variants further reduce forensic visibility by generating temporary directories with `Dir.mktmpdir` and automatically deleting the staging environment immediately after the package is prepared.

#4

The final stage turns RubyGems itself into a covert exfiltration channel. The implant creates a fake RubyGems environment under `/tmp/gemhome/.gem/`, injects hardcoded API credentials into a locally generated credentials file, adjusts permissions to satisfy gem client requirements, and overrides the HOME environment variable before pushing the malicious package to `rubygems.org`. Other variants bypass the gem client entirely and directly upload the .gem archive through crafted HTTP POST requests to the RubyGems API endpoint. Researchers observed the use of multiple API keys, likely as a resilience mechanism to ensure the campaign remains operational even if individual keys are revoked. From a network perspective, the activity appears nearly identical to legitimate developer behavior, a single outbound TLS connection carrying a gzip-compressed gem archive, making the exfiltration especially difficult to distinguish from normal software publishing traffic.

Recommendations



Yank All Identified Malicious Gem Packages: Run `gem yank` for each confirmed package name and version associated with the GemStuffer campaign. File an abuse report with `rubygems.org` requesting emergency removal of the full package set, as yanked gems may still be cached by mirrors.



Audit Temporary Directories on Ruby-Enabled Systems: Search `/tmp` on all potentially affected machines for artifacts matching `lambeth71b`, `rubydocran_`, `/tmp/gemhome/`, and any directory following the pattern `/tmp/[a-z]+[0-9]+[a-z]+[epoch_timestamp][pid]/`. Preserve and forensically image any matches before deletion.



Investigate Delivery Vectors in CI/CD and Developer Environments: Audit Bundler configuration files (`.bundler`, `Gemfile`, `config/application.rb`), gem post-install hooks, CI pipeline definitions, and dotfile repositories for references to `evil.rb`, `hack.rb`, `script.rb`, `payload.rb`, `exploit.rb`, `extconf.rb`, `fetcher.rb`, `yardload.rb`, or `yard_plugin.rb`.



Monitor HOME Environment Variable Mutations: Deploy runtime security tooling such as Falco or eBPF-based syscall monitors to alert on putenv/setenv calls that redirect HOME from /home or /root to /tmp paths within production Ruby processes. This is an abnormal operation in any legitimate Ruby application.



Block Outbound gem push in Non-Publishing CI Pipelines: For CI workflows that do not legitimately publish to rubygems.org, add egress rules blocking HTTPS POST requests to rubygems.org/api/v1/gems. For pipelines that do publish, restrict allowed gem names to an explicit allowlist.



Harden Ruby Application Environments Against Credential Injection: Restrict write access to /tmp in production containers where Ruby workloads run. Use read-only filesystem mounts where possible and monitor for credential file creation under non-standard HOME paths.



Review RubyGems Account Security and New Package Alerts: Enable notifications for new gem publications under organizational accounts. Audit RubyGems API key scopes and rotate keys on a regular cadence. Note that RubyGems temporarily disabled new account registration in response to the broader spam-publishing campaign this activity overlaps with.



Potential MITRE ATT&CK TTPs

Tactic	Technique	Sub-technique
Reconnaissance	<u>T1592</u> : Gather Victim Host Information	
Resource Development	<u>T1608</u> : Stage Capabilities	
Initial Access	<u>T1190</u> : Exploit Public-Facing Application	
Execution	<u>T1059</u> : Command and Scripting Interpreter	<u>T1059.006</u> : Python



Tactic	Technique	Sub-technique
Defense Evasion	<u>T1036</u> : Masquerading	<u>T1036.005</u> : Match Legitimate Name or Location
	<u>T1564</u> : Hide Artifacts	<u>T1564.002</u> : Hidden Users
Collection	<u>T1213</u> : Data from Information Repositories	
	<u>T1119</u> : Automated Collection	
Exfiltration	<u>T1567</u> : Exfiltration Over Web Service	
Command and Control	<u>T1071</u> : Application Layer Protocol	<u>T1071.001</u> : Web Protocols
	<u>T1132</u> : Data Encoding	
Discovery	<u>T1057</u> : Process Discovery	

✂ Indicators of Compromise (IOCs)

TYPE	VALUE
SHA256	239440c830e17530dda0a8a06ed2708860998750a1e3ed2239e919465dc59420, c2d6bcacc88177e0f2c8c262726f86f37e671b1692c8bc135bac4b610ddcf31a
SHA1	5f924c0454f1fb6b2299d658c3bb4e75ce3d0b66, db9827ae2c004a4dc6009be2d009477bff5249df
MD5	81c34eea9c853c5ec13a3b3cd4a2228b, 9211506ae02c9e4e75aeadfebeb4883c

TYPE	VALUE
Filenames	payload.rb, script.rb, evil.rb, yardload.rb, yard_plugin.rb, exploit.rb, extconf.rb, fetcher.rb
URLs	hxxps[:]//moderngov[.]lambeth[.]gov[.]uk/mgCalendarMonthView[.]aspx?M=1&Y=2026&GL=1&bcr=1, hxxps[:]//democracy[.]wandsworth[.]gov[.]uk/mgCalendarMonthView[.]aspx?M=1&Y=2026&GL=1&bcr=1, hxxps[:]//moderngov[.]southwark[.]gov[.]uk/mgCalendarMonthView[.]aspx?M=1&Y=2026&GL=1&bcr=1
File System Artifact	/tmp/<package><epoch_timestamp><pid>/, /tmp/<package><epoch_timestamp><pid>/lib/result.txt, /tmp/<package><epoch_timestamp><pid>/lib/x.rb, /tmp/<package><epoch_timestamp><pid>/x.gemspec, /tmp/<package><epoch_timestamp><pid>/<package>-0.0.2.gem, /tmp/<package><epoch_timestamp><pid>/log, /tmp/gemhome/.gem/credentials — fabricated credentials file containing hardcoded API key, /tmp/gemhome/, /tmp/rubydocran_*
Malicious Gem Packages	s.summary='result', s.summary='o', s.authors=['x'], s.authors=['a'], s.authors=['south']



References

<https://socket.dev/blog/gemstuffer>



What Next?

At Hive Pro, it is our mission to detect the most likely threats to your organization and to help you prevent them from happening.

Book a Demo of HivePro.

REPORT GENERATED ON

May 14, 2026 • 09:30 AM

© 2026 All Rights are Reserved by Hive Pro



More at www.hivepro.com